

External Network Scanning & Firewall Security Validation Report

Author

Mohamed Ibrahim Shire

Executive Summary

This project simulated an external reconnaissance and network enumeration attack against an internal Windows 10 host protected by a pfSense firewall. The objective was to assess the effectiveness of firewall policies in preventing unauthorized network discovery and service enumeration from an untrusted network.

Using a Kali Linux attacker system, multiple Nmap scanning techniques were executed against the target host during two separate phases:

1. Permissive Firewall Configuration (Allow All)
2. Hardened Firewall Configuration (Block Rule Enforcement)

The assessment demonstrated how improper firewall policies expose internal assets to reconnaissance activities and how properly configured filtering rules significantly reduce the attack surface. Validation was performed through external scanning results and internal firewall log analysis.

The project successfully confirmed that pfSense effectively blocked unauthorized traffic and prevented service discovery after security controls were implemented.

Project Objectives

The primary objectives of this assessment were:

- Simulate an external attacker performing reconnaissance.
 - Identify exposed services on an internal Windows host.
 - Validate pfSense firewall policy enforcement.
 - Demonstrate attack surface reduction through rule hardening.
 - Verify blocked traffic using firewall logs.
 - Document security improvements through before-and-after testing.
-

Lab Environment

Infrastructure Components

Device	Role
Kali Linux	External Attacker
pfSense	Firewall Gateway
Windows 10	Internal Target
VirtualBox	Virtualization Platform

Network Architecture

External Network (WAN)

↓

Kali Linux Attacker

10.128.120.200

↓

pfSense Firewall

WAN: 10.128.120.64

LAN: 192.168.1.1

↓

Windows 10 Target

192.168.1.100

The pfSense firewall served as the security boundary between the attacker network and the protected internal network.

Assessment Methodology

The assessment followed a structured security validation process.

Phase 1

Baseline Reconnaissance

Firewall configured to allow traffic.

Phase 2

Security Hardening

Firewall block rule implemented.

Phase 3

Control Validation

Firewall logs reviewed to verify enforcement.

Phase 1: External Reconnaissance Assessment

Objective

Determine the level of visibility an attacker has when firewall restrictions are absent.

Firewall State

Allow-All Rule Enabled

Evidence Screenshot:

- Allow all firewall rule
 - Open service discovery results
-

Host Discovery

Command:

`nmap -sn 192.168.1.100`

Findings

The target responded successfully to host discovery probes.

Assessment:

An attacker can easily identify active systems within the environment.

TCP SYN Port Scan

Command:

```
nmap -sS -p- 192.168.1.100
```

Findings

Multiple services were identified, including:

- SSH (22)
- HTTP (80)
- MSRPC (135)
- NetBIOS (139)
- SMB (445)

Additional high-numbered ports were also observed.

Security Impact

Exposure of these services provides attackers with valuable intelligence regarding:

- Operating system fingerprinting
 - Service enumeration
 - Vulnerability identification
 - Attack path development
-

Firewall Behavior Validation

Command:

```
nmap -sA 192.168.1.100
```

Findings

The ACK scan reported filtered ports.

Analysis

This behavior indicates that pfSense was operating as a stateful firewall and was dropping packets that did not belong to established sessions.

Although services remained accessible, the firewall correctly enforced stateful inspection mechanisms.

Risk Assessment

Security Exposure Identified

Risk	Impact
Host Discovery	High
Service Enumeration	High
Internal Asset Visibility	High
Reconnaissance Success	High

Overall Risk Level: High

Phase 2: Firewall Hardening & Policy Enforcement

Security Objective

Eliminate external visibility of internal services.

Firewall Rule Implemented

Action: Block

Interface: WAN

Source IP: 10.128.120.200

Destination IP: 192.168.1.100

Behavior: Silent Drop

This rule was specifically designed to prevent communication from the attacker system to the internal target.

Security Validation Testing

Post-Hardening Scan

Command:

```
nmap -Pn -sS 192.168.1.100
```

Findings

No accessible services were identified.

All scanned ports returned as:

- Filtered
- No Response

Analysis

The firewall successfully prevented the attacker from determining:

- Running services
- Open ports
- Application exposure
- System accessibility

The attack surface was effectively reduced to zero from the attacker's perspective.

Reconnaissance Evasion Verification

Additional targeted scans were executed against previously discovered services.

Examples:

- Port 22 (SSH)
- Port 80 (HTTP)
- Port 135 (MSRPC)
- Port 139 (NetBIOS)
- Port 443 (HTTPS)

Results:

All services appeared filtered and inaccessible.

This confirmed successful enforcement of the security policy.

Firewall Log Analysis

Objective

Verify that the firewall—not the target host—was responsible for blocking traffic.

Evidence Review

pfSense firewall logs showed repeated blocked connections originating from:

Source IP:

10.128.120.200

Destination:

192.168.1.100

Rule Triggered:

Default Deny IPv4 Rule

Investigation Findings

The logs confirmed:

- Traffic reached the WAN interface.
- Packets matched firewall policies.
- Connections were denied before reaching the target host.
- Security controls functioned as intended.

Security Control Effectiveness

Control	Status
Host Discovery Prevention	Successful
Port Enumeration Prevention	Successful
Unauthorized Access Prevention	Successful

Control	Status
Stateful Inspection	Successful
Traffic Logging	Successful
Policy Enforcement Validation	Successful

Lessons Learned

This project demonstrated how reconnaissance activities can quickly reveal valuable information about internal assets when firewall policies are overly permissive.

By implementing targeted filtering rules and validating their effectiveness through external testing and internal logging, the organization significantly reduced the exposed attack surface.

The exercise reinforced the importance of:

- Principle of least privilege
- Network segmentation
- Stateful packet inspection
- Continuous firewall monitoring
- Defense-in-depth security architecture

Conclusion

This assessment successfully simulated a real-world reconnaissance attempt against an internal Windows host and validated the effectiveness of pfSense firewall controls.

Initial testing demonstrated that exposed services could be identified through standard Nmap enumeration techniques. After implementing a restrictive firewall policy, all reconnaissance attempts were blocked, and no service information was exposed to the attacker.

Firewall log analysis confirmed that security policies were enforced correctly and prevented unauthorized access to internal resources.

The project demonstrates practical skills in network security, firewall administration, reconnaissance detection, attack surface reduction, and security validation—core competencies required for SOC Analyst, Blue Team, and Security Operations roles.